GUIDE DE SÉCURITÉ SUR LA GESTION DES MENACES

Avis de confidentialité

Ce document contient des informations qui sont destinées à l'usage exclusif de iA Groupe financier.

Sous réserve d'une approbation d'un représentant dûment autorisé de iA Groupe financier, toute reproduction de ce document, ou sa distribution à l'extérieur de son groupe autorisé d'utilisateurs est interdite.

Table des matières

1. Introduction 3
2. Cadre de référence de la « Cyber Kill Chain » 4
3. Vecteurs d'attaque 5

Annexe A. Registre d'approbation 6

Annexe B. Historique des révisions 6

Guide de sécurité sur la Gestion des menaces	
Propriétaire du guide	Directeur, Protection et analyse en sécurité de l'information
Portée	Le présent Guide de sécurité s'applique à toutes les activités de iA Groupe financier, dans toutes les juridictions où l'organisation opère. Elle couvre tous ses employés, fournisseurs de services, sous-traitants et autres personnes dont le travail relève de la responsabilité de la direction de l'entreprise, sous son contrôle direct et utilisant ses informations ou actifs.
Date de révision	2023-11-01
Date d'approbation	2023-11-05
Date d'entrée en vigueur	2021-11-01
Fréquence de révision	Au besoin

1. Introduction

Le « *Guide de Sécurité sur la Gestion des menaces* » permet de préciser les exigences de la « *Norme de Sécurité sur la Gestion des Menaces* ». En cas de divergence entre ce Guide et la Norme, cette dernière prévaut.

2. Cadre de référence de la « Cyber Kill Chain »

Le tableau suivant donne un aperçu complet des phases de la « Cyber Kill Chain » avec des exemples :

Phase	Description	Exemple
Reconnaissance	Identification, sélection et profilage de la cible.	Collecte d'adresses courriel, d'informations de conférence, etc.
Armement (Weaponize)	Couplage d'un exploit avec une porte dérobée dans une charge utile livrable appelée une cyberarme.	Couplage d'un cheval de Troie d'accès à distance dans un document Microsoft Office par le biais d'un exploit.
Livraison	Transmission de la cyberarme à l'environnement ciblé.	Livraison de la cyberarme par courriel, web, USB, etc.
Exploitation	Déclenchement de la charge utile de la cyberarme sur le système cible.	La cyberarme (p. ex. pièce jointe de document Word) est ouverte ou exploite une fonctionnalité du système d'exploitation pour s'exécuter automatiquement.
Installation	Installation d'une porte dérobée et maintien de la persistance.	Création d'un point d'accès qui permet un accès non autorisé à distance à l'ordinateur et au réseau.
Commande et contrôle	Canal de commande pour la manipulation à distance du système de la Société.	Serveurs de contrôleur Internet sortants pour communiquer avec l'hôte compromis.
Agir sur l'objectif	En utilisant leur accès nouvellement acquis, les intrus accomplissent leurs objectifs initiaux.	Exfiltration des données, propagation du réseau, perturbation du système, etc.

Tableau 1 : Aperçu des phases

3. Vecteurs d'attaque

Le tableau ci-dessous énumère les méthodes courantes d'attaque utilisées dans le profilage des menaces.

Vecteur d'attaque	Description	Exemple
Supports externes/ amovibles	Une attaque exécutée à partir d'un support amovible ou d'un périphérique.	- Code malveillant se propageant sur un système à partir d'une clé USB infectée.
Attrition	Une attaque qui utilise des méthodes de force brute pour compromettre, dégrader ou détruire des systèmes, des réseaux ou des services.	- Attaque DDoS destinée à compromettre ou à refuser l'accès à un service ou à une application. - Attaque par force brute contre un mécanisme d'authentification, comme les mots de passe, les CAPTCHAS ou les signatures numériques.
Web	Une attaque exécutée à partir d'un site Web ou d'une application web.	- Attaque de scripting intersite (« *cross-site scripting* » ou *XSS)* utilisée pour voler des informations d'identification ou rediriger vers un site qui exploite une vulnérabilité d'un navigateur et installe des logiciels malveillants.
Courrier électronique	Une attaque exécutée via un message électronique ou une pièce jointe.	- Code d'exploitation déguisé en pièce jointe ou en lien vers un site Web malveillant dans le corps d'un message électronique.
Usurpation d'identité	Une attaque impliquant le remplacement d'un élément bénin par quelque chose de malveillant.	- Spoofing - Attaque de type « *man in the middle* » - Points d'accès sans fil malveillants - Attaques par injection SQL.
Usage inapproprié	Tout incident résultant d'une violation des politiques d'utilisation acceptables de la Société par un utilisateur autorisé, à l'exclusion des catégories ci-dessus.	- L'utilisateur installe un logiciel de partage de fichiers, ce qui entraîne la perte de données sensibles. - L'utilisateur effectue des activités illégales sur un système.
Perte ou vol d'équipement	La perte ou le vol d'un appareil ou d'un support informatique utilisé par la Société.	- Perte d'un ordinateur portable - Vol de téléphone intelligent - Perte de jetons d'authentification

Annexe A. Registre d'approbation

Approbateur (v 1.0)		Date
Propriétaire	Louis Buteau-Vaillancourt, Directeur, Protection et analyse en sécurité de l'information	

Annexe B. Historique des révisions

Version	Impact	Auteur	Changements	Date
1.0	Majeur	Stephane Gauthier	Transfert des annexes de la norme Gestion des menaces dans ce guide.	2025-02-05